07 - API Specification

Generated 2026-10-14 from 07-API-SPECIFICATION.md - information only, not medical advice.

Contents

Endpoints

Request: ChatRequest

Response: ChatAnswer

Errors

Machine-readable schema generated from the running app: `api/openapi.json` (regenerate after API changes). In compose/Kubernetes the browser calls the API through the frontend (same origin). Authentication: `Authorization: Bearer <Supabase access token>` (ES256/RS256, JWKS).

Endpoints

Method	Path	Role	Purpose
GET	`/healthz`	public	Liveness (no dependency checks)
GET	`/readyz`	public	Readiness (database ping)
GET	`/metrics`	public*	Prometheus metrics (*NetworkPolicy + optional `METRICS_TOKEN`; not exposed via nginx)
GET	`/api/config`	public	Supabase URL + publishable key, emergency number, research availability
GET	`/api/me`	user	Caller id, email, role
POST	`/api/chat`	user	Answer a question (JSON `ChatAnswer`)
POST	`/api/chat/stream?mode=chat|research`	user (research: clinician)	Same answer as SSE: `phase` events then `answer` or `error`
POST	`/api/research`	clinician	Research mode (corpus + allow-listed web)
GET	`/api/sources`	user	Publishers, doc types, trusted documents, caller's uploads (for "Search in")
GET/POST	`/api/documents`	user	List / upload own (untrusted, private) documents
DELETE	`/api/documents/{doc_id}`	user	Delete own document (404 if not owner)
GET/POST	`/api/admin/documents`	admin	List / ingest trusted documents (allow-listed publishers, provenance form fields)
DELETE	`/api/admin/documents/{doc_id}`	admin	Delete a trusted document and its chunks
GET	`/api/conversations`	user	Own conversation list
GET/DELETE	`/api/conversations/{id}`	user	Own conversation messages / delete it
DELETE	`/api/conversations`	user	Delete all own history
GET	`/api/conversations/{id}/report`	user	Evidence report (Markdown download)

Method	Path	Role	Purpose
GET	`/api/review/queue` · POST `/api/review/{id}` · GET `/api/review/summary`	clinician	Review queue, verdicts, summary
GET	`/api/admin/review/export?format=json|csv`	admin	Export verdicts
GET	`/api/admin/evaluations`	admin	Latest evaluation runs (labelled synthetic offline) + review summary
GET	`/api/admin/safety-rules`	admin	Red-flag rules version/status/categories

Request: `ChatRequest`

```
{"question": "What is hypertension?", "conversation_id": null,
 "filters": {"trusted_only": false, "publishers": [], "doc_ids": [], "doc_types": [],
             "jurisdiction": null, "date_from": null, "date_to": null}}
```

Unknown fields are ignored; filters only narrow retrieval and can never disable safety.

Response: `ChatAnswer`

Field	Meaning
`kind`	answer · refusal · emergency · not_covered · redirect
`scope`	info · research · personal_diagnosis · prescribing_or_dosing · emergency · out_of_scope · unsafe
`emergency`	`{message, number, crisis_message, poison_message, categories}` - render first
`preface`	Refusal/referral wording shown before the answer
`answer`	Cited text (`[n]` markers)
`warnings`	Medicine-change warning, version conflicts, staleness
`citations[]`	n, title, publisher, source, location, publication_date, version, evidence_level, url, trusted, user_provided, stale, superseded
`evidence_basis`, `limitations`, `disclaimer`	Fixed wording added in code
`safety`	triage detectors, rules version, check results, high_risk, guardrail events, `trace` (no text)
`safety.trace[]`	Agent trace ("How this answer was produced"): `{agent, outcome, detail, status, ms}` per step in pipeline order, ending with `Result`; `status` is `ok` · `warn` · `stop` · `skip`; `ms` = step duration. Decisions and counts only - never question, answer or passage text or upload filenames. Default `[]`
`conversation_id`, `research`, `cached`, `request_id`	Bookkeeping

Errors

`{"detail": "...", "error": "<Type>"}` with: 401 (sign-in), 403 (role), 404 (missing or not yours), 413 (too large), 415 (file type), 422 (invalid input / unlisted publisher), 429 (provider quota or per-user rate limit, with `Retry-After`), 502 (provider error), 503 (provider unreachable / all circuits open / research not configured).